

PATA DE VELUDO / ADMIN

painel admin — sistema separado

Sistema separado

JWT ADMIN

Apenas via API REST

**acesso exclusivo via api rest**

O admin é um sistema separado. Nunca acessa o banco de dados diretamente. Toda operação passa pela API REST com autenticação ADMIN. Isso garante que todas as ações fiquem auditadas e que a superfície de ataque seja minimizada.

por que separado



Segurança

Superfície de ataque menor.
Credenciais admin não ficam no mesmo bundle da loja pública.



Escalabilidade

Deploy independente permite escalar loja e admin em momentos diferentes sem conflito.



Auditoria

Log centralizado na API. Cada ação admin gera entrada de auditoria automaticamente.



Manutenção

Times separados podem trabalhar na loja e no admin sem merge conflicts ou deploys acoplados.

autenticação

JWT com role ADMIN. Endpoints exclusivos no prefixo `/api/admin/**` — inacessíveis para tokens de cliente.

ROLE EXIGIDA**ADMIN**validado em cada request
via @PreAuthorize**ACCESS TOKEN****2 horas**expiração mais curta que
token de cliente**REFRESH TOKEN****7 dias**armazenado em httpOnly
cookie no admin**PREFIXO DE ROTAS****/api/admin/****protegidas por
SecurityFilterChain
separado

endpoints admin

Todos os endpoints abaixo requerem token com role ADMIN no header Authorization: Bearer <token>.

GET /api/admin/dashboard

KPIs: receita, pedidos, conversão

GET /api/admin/orders

Lista pedidos com filtros e paginação

GET /api/admin/orders/{id}

Detalhe completo do pedido

PATCH /api/admin/orders/{id}/status

Altera status do pedido

POST /api/admin/orders/{id}/ship

Marca pedido como enviado + código de rastreio

POST /api/admin/orders/{id}/cancel

Cancela pedido e dispara reembolso

GET /api/admin/products

Inventário completo com estoque

POST /api/admin/products

Cria novo produto

PUT /api/admin/products/{id}

Edita produto (preço, estoque, descrição)

GET /api/admin/customers

Lista clientes com busca e filtros

GET /api/admin/analytics

Dados de observabilidade e métricas

deploy



Subdomínio separado

Admin roda em domínio próprio, isolado da loja.

`admin.patadeveludo.com.br`



Env vars próprias

Credenciais e secrets do admin nunca compartilhados com o repo da loja.

`ADMIN_API_URL`, `ADMIN_JWT_SECRET`



CORS restrito

API só aceita requests do domínio admin — configurado em `CORS_ADMIN_ORIGINS`.

`whitelist por domínio`



CI/CD independente

Pipeline separado no GitHub Actions. Deploy não depende do deploy da loja.

`velvet-admin/.github/`

roadmap

atual

Admin como frontend separado

Next.js independente, comunicação 100% via API REST autenticada. Banco de dados compartilhado (read/write via API).

v2

Réplica read-only para o admin

Roteamento de queries pesadas de analytics para réplica PostgreSQL. Reduz carga na instância principal sem alterar contratos da API.

v3

Eventual separação para microsserviço

Se o volume justificar: extrair AdminService para microsserviço próprio com banco separado, comunicando via eventos (Kafka/SQS). A separação atual de frontend/API facilita essa migração futura com mínimo retrabalho.